



# Fortinet Cybersecurity Academy – Configuring a Remote Access IPsec VPN on a FortiGate 40F

Yuuki Burleigh – CCNA | AWS CCP

## **Purpose**

This lab contributes to developing the understanding of how Remote Access Virtual Private Networks or VPNs are configured and put into practical use using a FortiGate 40F firewall. This lab additionally helps develop the skills of configuring RA VPNs by creating one and logging into a remote computer in a separate network. Being able to understand how to create a Remote Access VPN is extremely valuable as workforces continue to have a remote working environment allowing for organizations to expand their talent acquisition scope to global scales.

## **Background**

VPNs or Virtual Private Networks are a way to have a secure encrypted connection over the internet by masking the IP address of the original sender. This means that any user that connects to a VPN service is contacting a VPN server so that the user can use the server's address instead of their own. The connection to the server is encrypted so that malicious actors cannot read any data they have collected over the connection between server and client. However, connecting to a VPN does not mean that information that is sent or requested is completely safe from malicious actors. As stated before, the user is connecting to a VPN server, for whatever reason if that server is compromised or the service the user is connecting to is in fact malicious any information sent to the server, once successfully connected and authenticated, can be captured and sold or used by malicious actors. Additionally, even if server is not compromised if the user is sending or requesting information from malicious sites, the VPN may fail to filter that site and forward malicious packets or malware to the user. The previous situation is both fault of the user for trying to access a malicious site and the VPN service for not being able to filter malicious web traffic. VPNs should only be used if the service providers are trusted to prevent unnecessary risk.

A Remote Access VPN operates just like a regular VPN but is built for a separate purpose. A remote access VPN is used mainly for allowing people from outside an intranet (Internal Network which can contain sensitive company/organizational information) to access resources within it. A common case is for remote workers. If an employee wishes to work from home, an organization can create a VPN server that is connected to the on-premises network but faces the internet so that anyone from the internet can access the VPN gateway. This poses obvious security risks as the VPN can then be accessed from anywhere and by anyone, to prevent this most organizations implement authentication, this verifies the identity of anyone trying to connect to the VPN, this can either be done by storing a database of usernames and passwords and using that to authenticate users, or a company can issue laptops installed with certificates that can be authenticated via a database of authorized certificates. This is more secure but also poses another problem, what if a malicious actor, employee or not, is authenticated and has access to everything within the company network remotely? For this reason, companies implement authorization alongside authentication using the principle of least privilege, meaning users can only access what they need for their job or current task. Companies also implement Accounting, meaning they track actions that each user takes within the intranet. This allows companies to see who violates policy and actions they took that could have negatively

impacted the company to hold them accountable. Authentication, Authorization, and Accounting are abbreviated and known in the cyber security community as AAA or Triple A.

For a Fortinet Remote Access VPN, client software called FortiClient is needed. Once that software is installed it initiates a connection with the gateways, which is the Fortinet Firewall. Once the client tries to initiate the connection it sends the gateway/firewall to compare what algorithms they are capable of and agrees on what to use. Once they agree the encryption process begins. They both exchange nonces (random numbers) and public key values, then run an algorithm that produces the same shared secret value. Compare this to mixing paint, once mixed it cannot be undone. Both parties start with a public color/paint mix in their own private color along with their random color (nonces) and swap buckets and repeat. This will result in the same color or shared secret value, and because paint cannot be unmixed the private paint color and values cannot be known. Nonces are added so that the same shared secret is not used every time, allowing for better security.

Once the shared secret is derived encryption keys are derived from that shared secret using an algorithm. That key is called the SKYSEED which is used to derive keys for IKE encryption and integrity. The IKE channel can be thought of as the control channel that is used for authentication and changes in communication methods. From the SKYSEED the SK\_d is derived and from SK\_d the Child SA keys which are the real keys used for encryption of user traffic are derived.

But before the user traffic is encrypted the firewall prepared by the client by assigning the client its virtual IP addresses within the intranet and all the rules within the intranet and access rules set for the user.

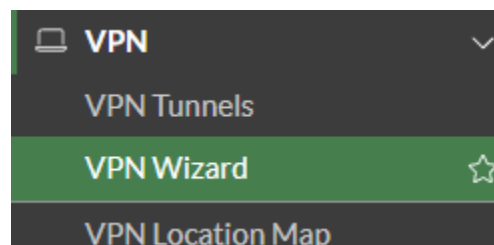
Just like most other applications there is a time limit to both the keys that encrypt real user data and the channel management data. But Fortinet in the background before the keys expire redoes the entire process for getting new keys within the encrypted IKE channel

Understanding these concepts allows for an easier time debugging the VPN is something that is not functioning as intended and additionally allows for the knowledge needed to create an original protocol to secure encryption as well. Further developing technical skills in a practical application.

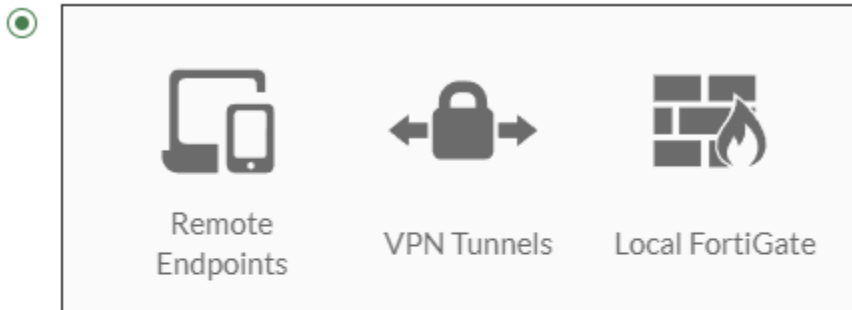
### Lab Commands

Login to the firewall,

Navigate to the VPN tab on the left Navigation Panel and select VPN Wizard.



Choose the remote access option.



### Remote Access

Employees who need to access their company's network from off-site locations or users who want to securely connect to a private network from a public area frequently use this type of VPN.

Supported remote clients:    

Name it.

Tunnel name

Kacin tunnel

Configure the Following under “VPN Tunnel”:

VPN Client Type: Fortinet

Authentication Method: Pre-Shared Key

Pre-Shared Key: Create your own

IKE: Version 2

Transport: Auto

NAT traversal: Enable

Keepalive Frequency: 10

EAP Peer Authentication: EAP Identity Request

User Authentication Method: Phase 1 Interface

DNS Server: Use System DNS

| VPN tunnel                   |                                        |
|------------------------------|----------------------------------------|
| VPN client type              | FortiClient Native                     |
| Authentication method        | Pre-shared key Signature               |
| Pre-shared key               | .....                                  |
| IKE                          | Version 2 Version 1                    |
| Transport ⓘ                  | UDP Auto                               |
| Use Fortinet encapsulation ⓘ | <input checked="" type="checkbox"/>    |
| NAT traversal                | Enable Disable Forced                  |
| Keepalive frequency          | 10                                     |
| EAP peer identification      | IKEv2 IDi payload EAP identity request |
| User authentication method   | Phase 1 interface Inherit from policy  |
|                              | 🔑 Admins                               |
| DNS Server                   | Use System DNS Specify                 |

These setting are mostly default and can be configured to fir your specific environment.

Under Remote Endpoint Configure:

Address to Assign to connected Endpoints/Subnets: A non-overlapping address range

Other settings can be configured optionally to the users will and specific use case

| + VPN tunnel                               |                                     |
|--------------------------------------------|-------------------------------------|
| - Remote endpoint                          |                                     |
| Addresses to assign to connected endpoints | 192.168.3.1-192.168.3.255           |
| Subnet for connected endpoints             | 255.255.255.0                       |
| <b>FortiClient settings</b>                |                                     |
| Security posture gateway matching ⓘ        | <input type="checkbox"/>            |
| EMS SN verification                        | <input type="checkbox"/>            |
| Save password                              | <input checked="" type="checkbox"/> |
| Auto Connect                               | <input type="checkbox"/>            |
| Always up (keep alive)                     | <input type="checkbox"/>            |

Under Local FortiGate you are configuring what internal network you want VPN users to be a part of and what interface you want users to connect from.

Under “Incoming Interface that Binds to a Tunnel” choose the interface outside users will connect from. (usually the WAN).

Under “Local Interface” and “Address” configure the address range that you want the outside user to be a part of.

## VPN Wizard - Kacin tunnel

  
Remote Endpoint

  
VPN Tunnel

  
Incoming

  
Local FortiGate

  
Internal

+ VPN tunnel

+ Remote endpoint

Local FortiGate

Incoming interface that binds to tunnel

wan

Create and add interface to zone☒

Local interface

lan

Local Address

lan

Then, name the objects you created relating to the VPN:

### Addresses

Split address group

 Kacin tunnel\_split



Address

 Kacin tunnel\_range



### Interfaces

VPN IPsec phase1 interface

 Kacin tunnel

Zone

☐ vpn\_Kacin tunnel\_zone



VPN IPsec Phase2 Interface

 Kacin tunnel

### Policies

Remote to local policy

vpn\_Kacin tunnel\_local\_allow



Finally Create a policy that allows VPN clients to have access to internal resources by creating a permit policy in the network policy tab. This allows outside traffic from VPN users only to access resources inside the network.

### Create New Policy

Name 📄

Schedule 🕒

Action ✓ ACCEPT ✗ DENY

Incoming interface 📶

Outgoing interface 🔄

Source & Destination Show logic

Source 📶

User/group 👤 Admins ✗  
👤 kacinvpn ✗

Destination 📶

Service 📶 ALL ✗

Next to test the VPN, download FortiClient and install it onto the outside computer.

FortiClient 7.4

FortiClient comes in several levels of capabilities, with increasing levels of protection. It integrates with many key components of the Fortinet Security Fabric and is centrally managed by the Endpoint Management Server (EMS)



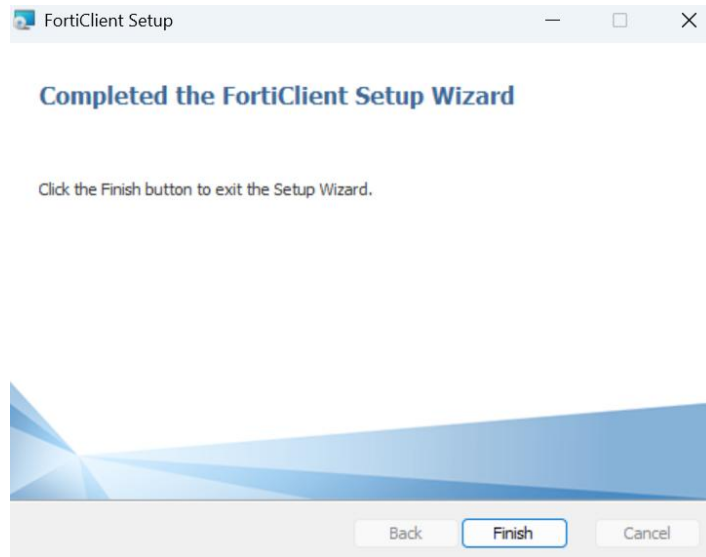
- ZTNA Edition
- EPP/APT Edition
- FortiClient EMS
- FortiClient Standalone Edition
- FortiClient VPN-only

#### ZTNA Edition

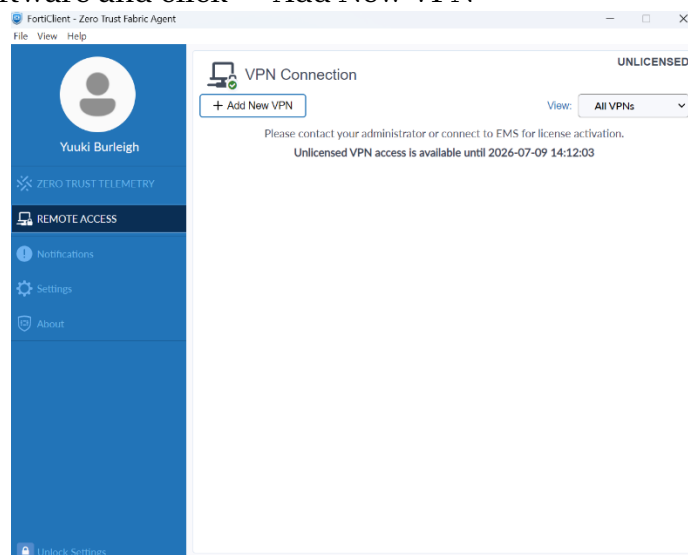
Technical Specification | How to Buy

- ✓ Zero Trust Application Access
- ✓ Real-time Endpoint Posture Checks
- ✓ Enhanced VPN with Continuous Assessment
- ✓ Vulnerability Agent & Remediation
- ✓ FortiGuard Web & Video Filtering
- ✓ Inline & API-based CASB
- ✓ Central Management via EMS
- ✓ Central Logging & Reporting Available





Open the software and click “+ Add New VPN”



Make sure the IPsec tab is selected at the top and fill in the details. The gateway address is the WAN port IP typically.

## ADD VPN

SSL-VPN

IPsec VPN

XML

Connection Name

kacinvpn

Description

Remote Gateway

192.168.40.3



+ Add Remote Gateway

Authentication Method

Pre-shared key



.....

Authentication (EAP)

☒ Prompt on login ☐ Save login ☐ Disable

Failover SSL VPN

[None]



Single Sign-On

☐ Enable Single Sign On (SSO) for VPN Tunnel

### VPN Settings



IKE

☒ Version 2

Address Assignment

☒ Mode Config

Encapsulation

☒ IKE UDP Port ☐ IPSec over TCP

Cancel

Save

A new entry should be added to the list. Press connect.

kacinvpn

Connect

Personal Standalone

Edit Delete

Enter the configured username and password.

FortiClient VPN Authentication



VPN: kacinvpn

 Username

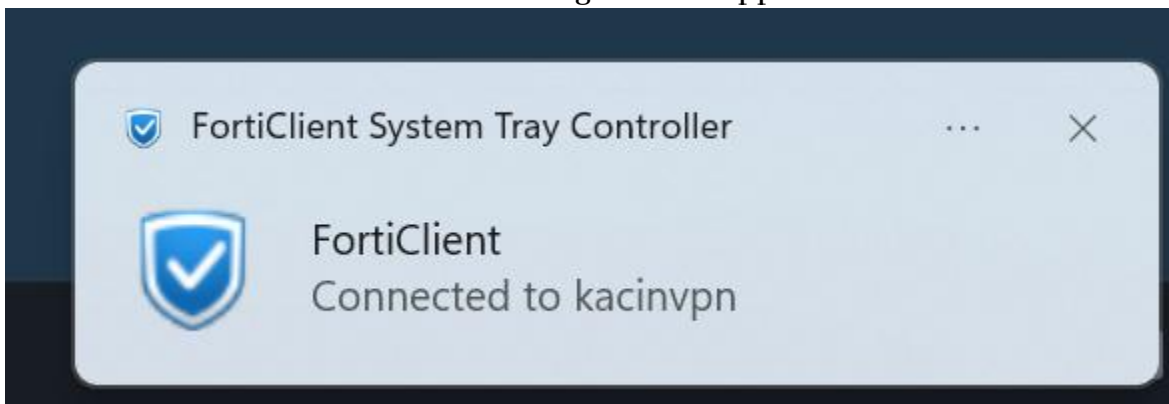
 Password



Cancel

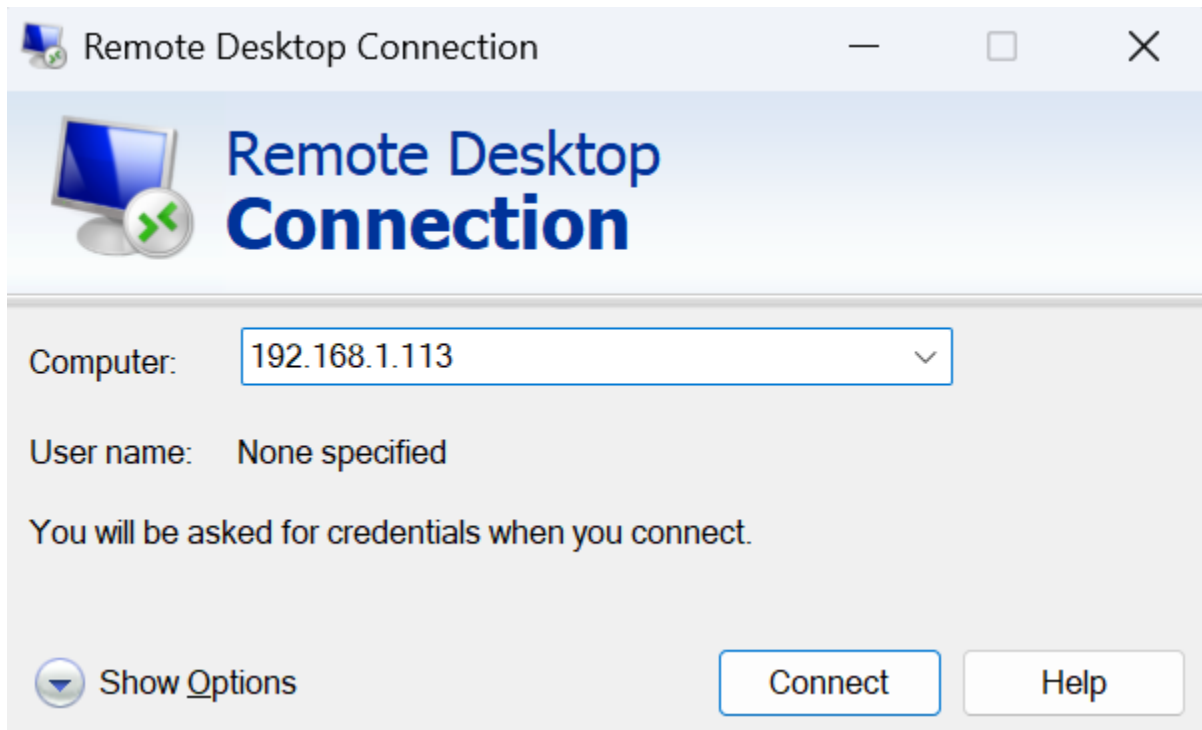
Connect

Press connect and a success message should appear.



Now to confirm you are in the network Remote desktop into an internal computer, do this by enabling remote desktop in settings and allow others to connect to your host.

Enter the IP address of the desired host or the hostname.



The image shows the 'Remote Desktop Connection' window. At the top, there's a title bar with a minimize button, a maximize button, and a close button. Below the title bar is a header area with a computer icon and the text 'Remote Desktop Connection'. The main area contains a 'Computer:' label followed by a text box containing '192.168.1.113'. Below this is a 'User name:' label followed by the text 'None specified'. A message states 'You will be asked for credentials when you connect.' At the bottom, there are three buttons: 'Show Options' (with a dropdown arrow), 'Connect', and 'Help'.

Remote Desktop Connection

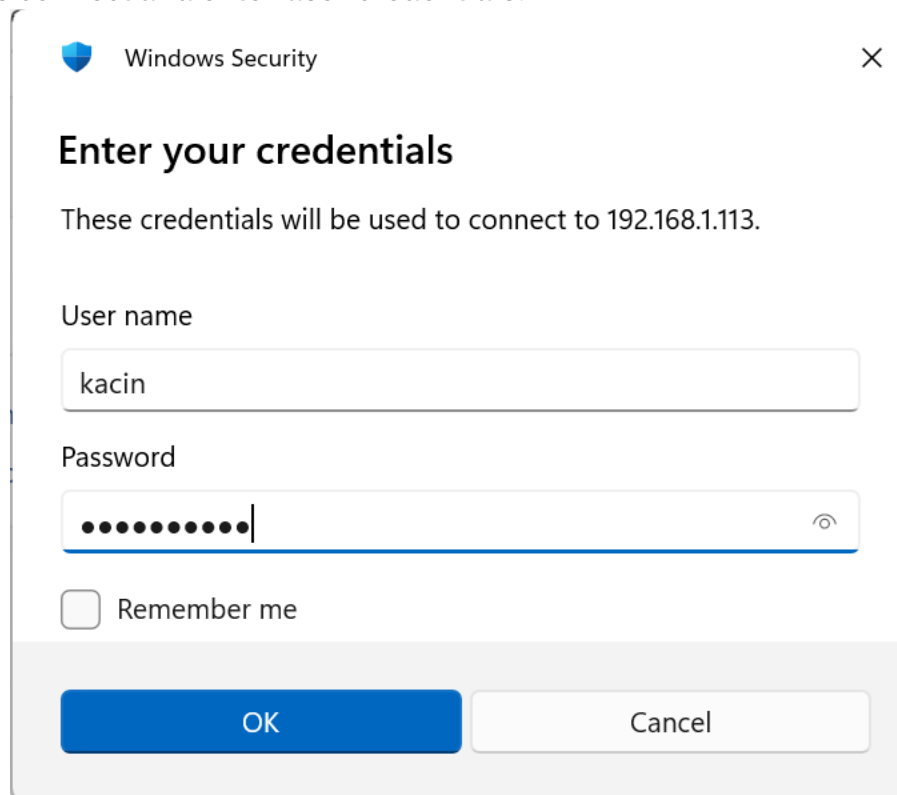
Computer: 192.168.1.113

User name: None specified

You will be asked for credentials when you connect.

Show Options Connect Help

Press connect and enter user credentials.



The image shows a 'Windows Security' dialog box titled 'Enter your credentials'. It informs the user that these credentials will be used to connect to 192.168.1.113. There are two input fields: 'User name' with the text 'kacin' and 'Password' with masked characters. Below the password field is a 'Remember me' checkbox which is unchecked. At the bottom are 'OK' and 'Cancel' buttons.

Windows Security

**Enter your credentials**

These credentials will be used to connect to 192.168.1.113.

User name

kacin

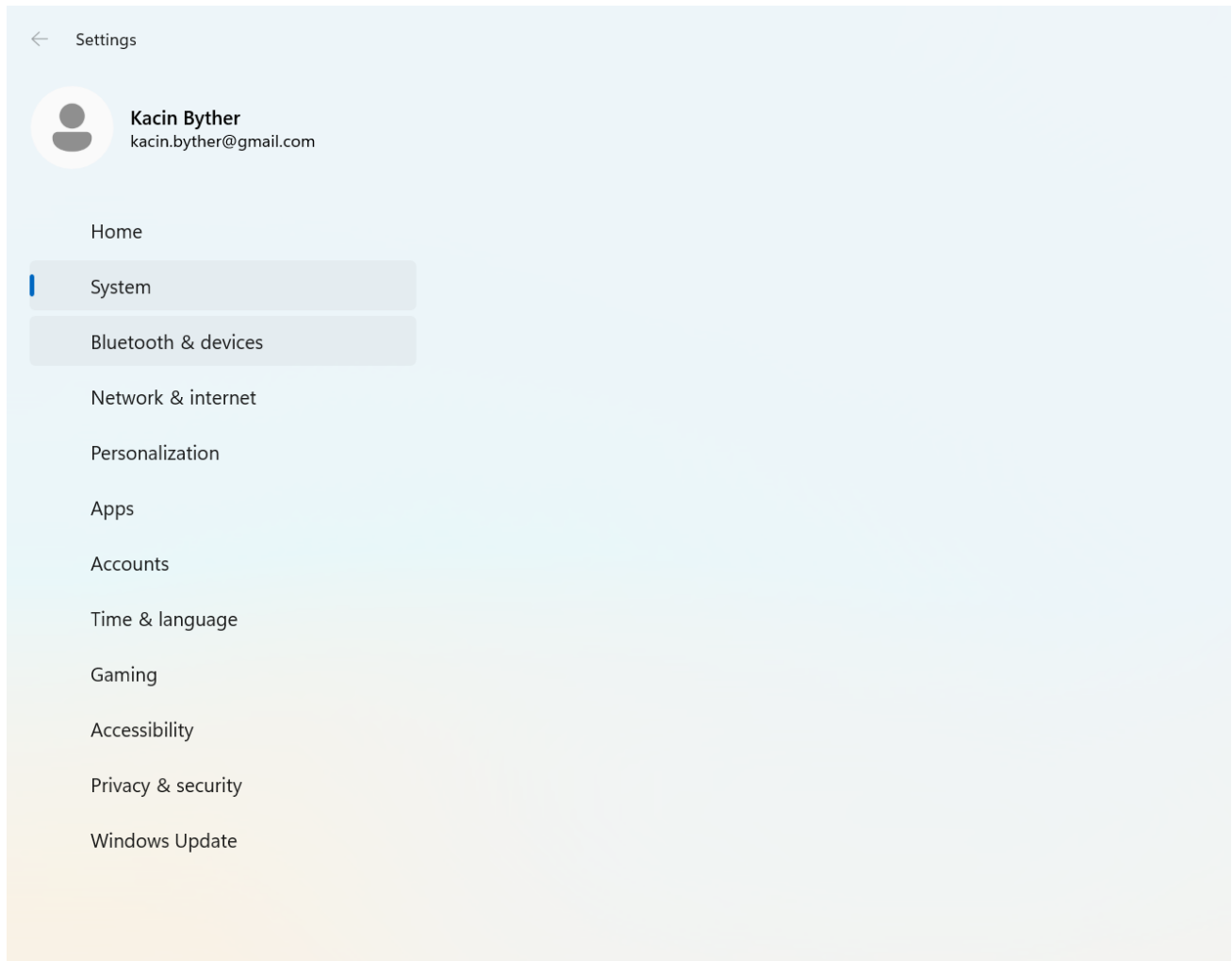
Password

.....

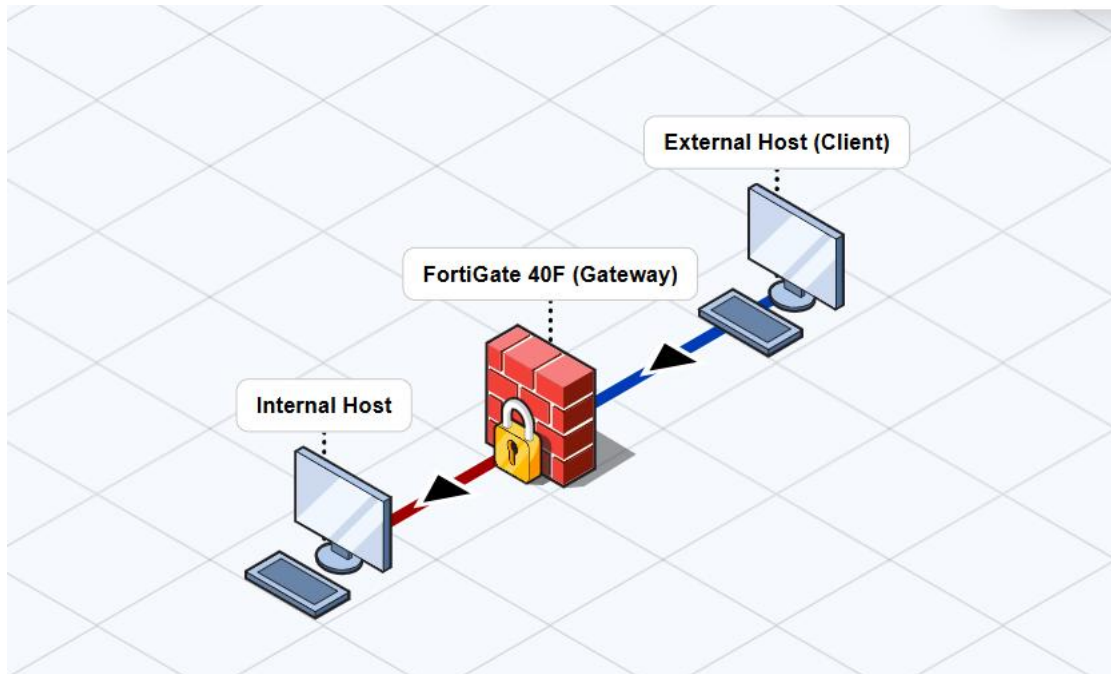
☐ Remember me

OK Cancel

As you can see the username listed into remote desktop login screen is shown in the top left proving that an outside host was able to access the internal host.



## Network Diagram



## Problems

During this lab I had a problem figuring out why I could not access the internet when connecting to the VPN, I later realized that this was because the intent policy did not allow for the assigned IP address of VPN users to access the WAN. To fix this I created a firewall policy to allow the VPN users to access WAN and therefore the internet.

Another problem when configuring the VPN was during the configuration of what group the VPN users would be assigned to. I did not know what address range and firewall ports to assign the VPN users at first but was able to understand what group to set it to after a quick search which allowed me to gain an understanding of how RA VPNs are configured and the importance of choosing the right subnet to assign VPN users as access to an unauthorized network can be catastrophic.

## Conclusion

In conclusion, this lab was extremely helpful in understanding how VPNs encrypt communication and how companies implement Remote Access VPNs to enable employees who may not be local to still do work with access to internal resources. This lab was especially helpful in drilling in the understand of concepts like Authentication, Authorization, and Accounting so that external users and malicious actors cannot access internal documents while properly authenticated and authorized users can.